

DetectKB

راه اندازی لب تست تشخیص روی vSphere

DetectKB به اتصال · Splunk · Sysmon · Atomic Red Team

ویرایش ۱ · مهر ۱۴۰۵

فهرست

۱. چه می‌سازیم و چرا
 ۲. آماده‌سازی vSphere و شبکه
 ۳. ماشین‌ها (VMها) و منابع
 ۴. راه‌اندازی SPLUNK-LAB
 ۵. راه‌اندازی WIN-VICTIM
 ۶. DC-LAB و LNX-VICTIM (اختیاری)
 ۷. نصب Atomic Red Team و اجرای اولین تست
 ۸. بررسی سلامت لب
 ۹. اتصال DetectKB به لب
 ۱۰. قواعد امنیتی لب
 ۱۱. چک‌لیست تحویل
-

مخاطب این سند: تیم زیرساخت (vSphere، شبکه، ویندوز) و تیم مهندسی تشخیص. هر فصل یک بخش مستقل است و آخر سند یک چک‌لیست تحویل آمده تا مشخص باشد چه چیزی آماده شده و چه چیزی مانده.

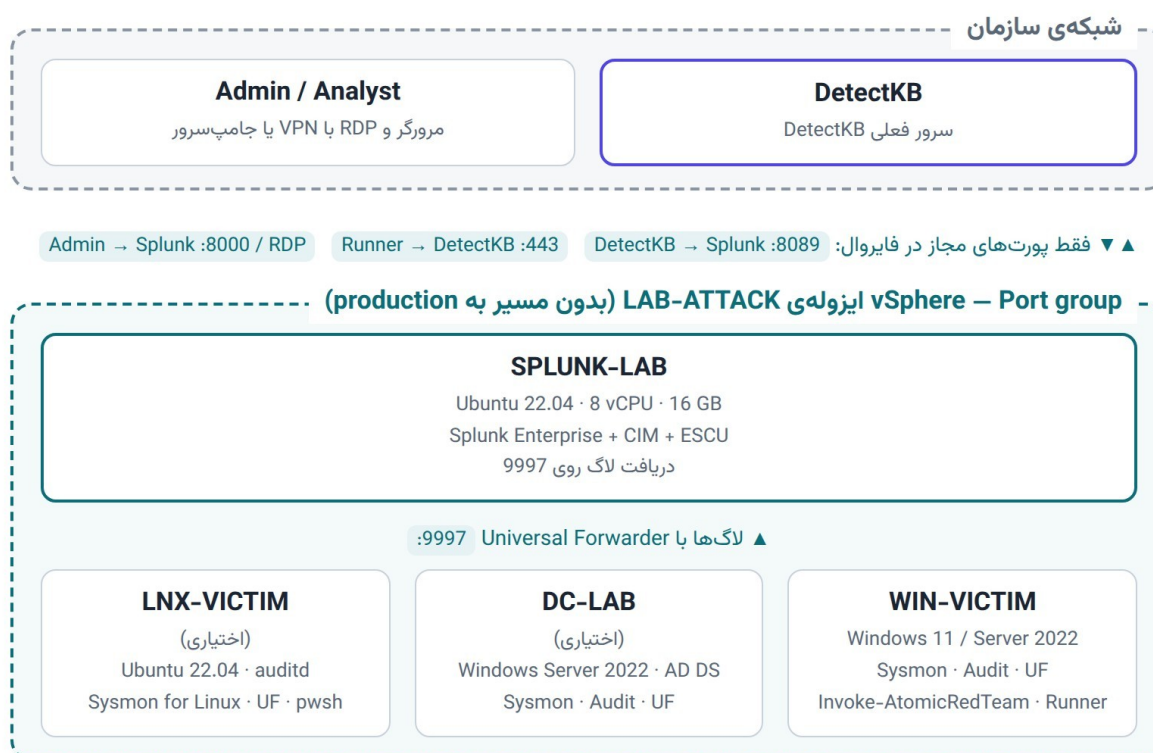
مقادیری مثل نام ماشین‌ها، IPها و نام indexها پیشنهادی‌اند؛ اگر عوضشان کردید، فقط در جدول فصل ۱۱ ثبت کنید تا در DetectKB همان‌ها تنظیم شود.

۱. چه می‌سازیم و چرا

DetectKB برای هر قانون تشخیص نشان می‌دهد کدام تست‌های **Atomic Red Team** باید آن را فعال کنند. برای اینکه مطمئن شویم قانون واقعاً کار می‌کند، باید آن تست‌ها را در یک محیط امن اجرا کنیم و ببینیم Splunk هشدار می‌دهد یا نه. این سند همان محیط امن («لب») را روی **vSphere** شرح می‌دهد.

چرا خود Attack Range را نصب نمی‌کنیم؟

Splunk Attack Range در نسخه‌ی فعلی (v5) فقط روی ابر (AWS، Azure، GCP) نصب می‌شود و روی vSphere اجرا نمی‌شود. به همین دلیل همان محتوای Attack Range را – یعنی Splunk، ویندوز با Sysmon و Forwarder، و Atomic Red Team – مستقیماً روی vSphere می‌سازیم. نتیجه همان لب است، فقط نصبش خودکار نیست.



شکل ۱ – نمای کلی لب روی vSphere و ارتباطش با DetectKB

سه قطعه‌ی اصلی

کارش	قطعه
لاگ همه‌ی ماشین‌های لب را جمع می‌کند و قانون‌ها روی آن اجرا می‌شوند.	SPLUNK-LAB
ماشین قربانی: حمله‌های آزمایشی روی آن اجرا می‌شود. Sysmon و لاگ‌های ویندوز را به Splunk	WIN-VICTIM

کارش	قطعه
می فرستد.	
می گوید کدام تست را اجرا کنیم و نتیجه را ثبت می کند. داخل لب نیست؛ فقط به Splunk وصل می شود.	DetectKB

۲. آماده سازی vSphere و شبکه

کارهای vSphere

- یک **Folder** و یک **Resource Pool** جدا به نام **LAB-ATTACK** بسازید و برایش سقف منابع بگذارید (مثلاً ۲۰ vCPU و ۴۸ گیگابایت RAM) تا لب روی سرویس های دیگر اثر نگذارد.
- یک **Port Group** (یا VLAN) جدید به نام **LAB-ATTACK** روی Distributed Switch بسازید. هیچ ماشین دیگری نباید روی آن باشد.
- ISOها را در Datastore بگذارید: Ubuntu Server 22.04، Windows Server 2022 (Evaluation)، Windows 11 Enterprise (Evaluation).
- روی همه ی VMها **VMware Tools** نصب شود.
- برای هر VM بعد از راه اندازی کامل یک Snapshot به نام **clean-baseline** بگیرید (فصل ۷).

شبکه و فایروال

لب باید از شبکه ی **production** جدا باشد. فقط این ارتباطها مجاز است:

از	به	پورت	برای چه
ماشین های لب	SPLUNK-LAB	9997/tcp	ارسال لاگ با Universal Forwarder (داخل لب)
DetectKB	SPLUNK-LAB	8089/tcp	اجرای کوئری قانونها با REST API (فاز ۳)
WIN-VICTIM / LNX-VICTIM	DetectKB	443/tcp	Runner: گرفتن تست از صف و گزارش نتیجه (فاز ۳)
ادمین / تحلیلگر	SPLUNK-LAB	8000/tcp	وب Splunk
ادمین	ماشین های لب	3389 / 22	RDP و SSH، ترجیحاً از جامپ سرور
ماشین های لب	اینترنت	443/tcp	فقط زمان نصب (دانلود، Sysmon، Splunk، Atomic)؛ بعد می توانید ببندید

توجه

هیچ مسیری از لب به شبکه ی production، Active Directory یا سرورهای واقعی نباید وجود داشته باشد. حمله های آزمایشی واقعی اند و ممکن است اسکن شبکه یا حرکت جانبی انجام دهند. ساعت همه ی ماشینها (NTP) باید درست باشد؛ DetectKB نتیجه را بر اساس بازه ی زمانی اجرای تست جستجو می کند.

IP و DNS پیشنهادی

ماشین	IP نمونه	نام DNS
SPLUNK-LAB	10.50.0.10	splunk-lab.lab.local
WIN-VICTIM	10.50.0.21	win-victim.lab.local
DC-LAB	10.50.0.20	dc-lab.lab.local
LNK-VICTIM	10.50.0.31	lnx-victim.lab.local

۳. ماشین‌ها (VM) و منابع

ماشین	سیستم عامل	vCPU	RAM	دیسک	لازم؟
SPLUNK-LAB	Ubuntu Server 22.04	8	GB 16	GB 200	بله
WIN-VICTIM	Windows 11 Ent یا Server 2022	4	GB 8	GB 80	بله
DC-LAB	Windows Server 2022 + AD DS	2	GB 6	GB 80	برای تکنیک‌های AD
LNK-VICTIM	Ubuntu Server 22.04	2	GB 4	GB 40	برای قانون‌های لینوکسی
جمع (همه)		16	GB 34	GB 400	

حداقل

برای شروع فقط **SPLUNK-LAB** و **WIN-VICTIM** کافی است (۲۴ vCPU، ۱۲ گیگابایت). DC و لینوکس را بعداً اضافه کنید.

لایسنس‌ها

نرم افزار	لایسنس پیشنهادی	نکته
Splunk Enterprise	Developer License (رایگان، ۱۰ گیگابایت در روز، قابل تمدید)	۶۰ روزه Trial هم هست. نسخه‌ی Free هشدار (Alert) و کاربر ندارد؛ برای ما مناسب نیست.
Windows 11 / Server 2022	Evaluation (۹۰ تا ۱۸۰ روز)	یا لایسنس‌های داخلی سازمان
Sysmon، Atomic Red Team	رایگان	

۴. راهاندازی SPLUNK-LAB

۴-۱. نصب Splunk

فایل نصب Splunk Enterprise برای لینوکس (.tgz) را از سایت Splunk دانلود و روی ماشین کپی کنید. سپس:

```
sudo useradd -m -r splunk
sudo tar xzf splunk-*-linux-amd64.tgz -C /opt
sudo chown -R splunk:splunk /opt/splunk
sudo -u splunk /opt/splunk/bin/splunk start --accept-license --answer-yes --seed-passwd 'CHANGE-ME-Strong-Pass'
sudo /opt/splunk/bin/splunk enable boot-start -user splunk --accept-license
```

۴-۲. دریافت لاگ و indexها

```
sudo -u splunk /opt/splunk/bin/splunk enable listen 9997 -auth admin:'CHANGE-ME-Strong-Pass'
sudo -u splunk /opt/splunk/bin/splunk add index win -auth admin:'CHANGE-ME-Strong-Pass'
sudo -u splunk /opt/splunk/bin/splunk add index sysmon -auth admin:'CHANGE-ME-Strong-Pass'
sudo -u splunk /opt/splunk/bin/splunk add index linux -auth admin:'CHANGE-ME-Strong-Pass'
```

۴-۳. اپهای لازم (از Splunkbase)

چرا	اپ
تجزیه‌ی Event Log های ویندوز (4104، 4688 و ...)	Splunk Add-on for Microsoft Windows (Splunk_TA_windows)
تجزیه‌ی رویدادهای Sysmon	Splunk Add-on for Sysmon (Splunk_TA_microsoft_sysmon)
بسیاری از قانون‌های ESCU با tstats روی دیتامدل‌ها (مثل Endpoint.Processes) کار می‌کنند	Splunk Common Information Model (Splunk_SA_CIM)
ماکروهایی که قانون‌های ESCU استفاده می‌کنند، مثل ماکروی sysmon و ماکروهای filter هر قانون	ES Content Update (DA-ESS-ContentUpdate)
فقط اگر LNX-VICTIM دارید	Splunk Add-on for Unix and Linux (اختیاری)

۴-۴. تنظیم‌های مهم بعد از نصب اپها

□ در **Settings → Roles → admin** (و نقشی که DetectKB استفاده می‌کند) indexهای **win**، **sysmon** و **linux** را به **Indexes searched by default** اضافه کنید. ماکروهای ESCU index مشخص نمی‌کنند و بدون این کار چیزی پیدا نمی‌کنند.

- در CIM، دیتامدل **Endpoint** را برای index های لب تنظیم کنید و **Acceleration** را روشن کنید؛ یا ماکروی `security_content_summariesonly` را روی `summariesonly=false` بگذارید تا قانون های `tstats` بدون شتابدهی هم نتیجه بدهند.
- رمز پیش فرض `admin` را عوض کنید و برای DetectKB یک کاربر جدا بسازید (فصل ۹).

۵. راهنمایی WIN-VICTIM

این مراحل را روی WIN-VICTIM (و بعداً DC-LAB) با PowerShell در حالت **Administrator** اجرا کنید.

۵-۱. Sysmon

Sysmon را از سایت Sysinternals و فایل پیکربندی را از پروژه **sysmon-modular** (olafhartong) دانلود کنید. این پیکربندی رویدادهای مهم مثل دسترسی به lsass (EID 10) را ثبت می‌کند.

```
.\Sysmon64.exe -accepteula -i .\sysmonconfig.xml
# Check:
Get-WinEvent -LogName 'Microsoft-Windows-Sysmon/Operational' -MaxEvents 5
```

۵-۲. Audit ویندوز

بدون این تنظیم‌ها رویدادهایی مثل 4688 (ساخت پروسه با خط فرمان) و 4104 (اسکرپت PowerShell) ثبت نمی‌شوند و بسیاری از قانون‌ها هیچ‌وقت فعال نمی‌شوند.

```
# Process creation (4688) with the command line
auditpol /set /subcategory:"Process Creation" /success:enable /failure:enable
reg add "HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System\Audit" /v
ProcessCreationIncludeCmdLine_Enabled /t REG_DWORD /d 1 /f

# Other events the rules use
auditpol /set /subcategory:"Logon" /success:enable /failure:enable
auditpol /set /subcategory:"Special Logon" /success:enable
auditpol /set /subcategory:"User Account Management" /success:enable /failure:enable
auditpol /set /subcategory:"Security Group Management" /success:enable
auditpol /set /subcategory:"Other Object Access Events" /success:enable /failure:enable
auditpol /set /subcategory:"Security System Extension" /success:enable
auditpol /set /subcategory:"File Share" /success:enable /failure:enable
auditpol /set /subcategory:"Audit Policy Change" /success:enable

# PowerShell: Script Block (4104) and Module Logging (4103)
reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging" /v
EnableScriptBlockLogging /t REG_DWORD /d 1 /f
reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ModuleLogging" /v
EnableModuleLogging /t REG_DWORD /d 1 /f
reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ModuleLogging\ModuleNames" /v
"" /t REG_SZ /d "" /f
```

برای DC

روی DC-LAB علاوه بر این‌ها **Kerberos Service Ticket Operations**، **Kerberos Authentication** و **Service Directory Service Changes** را هم فعال کنید (برای 4768، 4769 و 5136).

۵-۳. Splunk Universal Forwarder

```
msiexec.exe /i splunkforwarder-<version>-x64-release.msi AGREETOLICENSE=Yes
RECEIVING_INDEXER="10.50.0.10:9997" SPLUNKUSERNAME=admin SPLUNKPASSWORD="CHANGE-ME-UF"
/quiet
```

سپس فایل `C:\Program Files\SplunkUniversalForwarder\etc\system\local\inputs.conf` را با این محتوا بسازید و سرویس SplunkForwarder را ری استارت کنید:

```
[WinEventLog://Security]
disabled = 0
renderXml = true
index = win

[WinEventLog://System]
disabled = 0
renderXml = true
index = win

[WinEventLog://Microsoft-Windows-PowerShell/Operational]
disabled = 0
renderXml = true
index = win

[WinEventLog://Microsoft-Windows-Sysmon/Operational]
disabled = 0
renderXml = true
index = sysmon

[WinEventLog://Microsoft-Windows-TaskScheduler/Operational]
disabled = 0
renderXml = true
index = win
```

```
Restart-Service SplunkForwarder
```

۵-۴. آنتی ویروس (Defender)

خیلی از تست های Atomic را Defender قبل از اجرا متوقف می کند. دو حالت هر دو مفیدند، ولی باید مشخص باشد در کدام حالت تست کرده اید:

- **حالت تست قانون (پیشنهادی برای شروع):** برای پوشه `C:\AtomicRedTeam` استثنا (Exclusion) تعریف کنید تا حمله اجرا شود و ببینیم قانون SIEM آن را می گیرد یا نه.
- **حالت واقعی:** Defender کامل روشن؛ نشان می دهد در عمل چه چیزی جلوی حمله را می گیرد.

```
Add-MpPreference -ExclusionPath 'C:\AtomicRedTeam'
```

۶. DC-LAB و LNX-VICTIM (اختیاری)

DC-LAB

- Windows Server 2022 نصب و نقش **AD DS** با دامنه‌ی جدا (مثلاً `lab.local`) راه‌اندازی شود – هیچ Trust با دامنه‌ی سازمان.
- WIN-VICTIM عضو دامنه‌ی `lab.local` شود.
- همان مراحل فصل ۵ (Sysmon، Audit، Forwarder) روی DC هم انجام شود.
- چند کاربر و گروه آزمایشی و یک حساب سرویس با SPN بسازید تا تست‌هایی مثل Kerberoasting معنی داشته باشند.

LNX-VICTIM

- نصب **auditd** و **Sysmon for Linux** (از مخزن بسته‌های Microsoft).
- نصب Splunk Universal Forwarder برای لینوکس، فرستادن `/var/log/audit/audit.log`، `/var/log/syslog` و لاگ Sysmon به `linux` index.
- نصب **PowerShell 7** (`pwsh`) تا Invoke-AtomicRedTeam روی لینوکس هم کار کند.

۷. نصب Atomic Red Team و اجرای اولین تست

۷-۱. نصب روی WIN-VICTIM

```
Set-ExecutionPolicy Bypass -Scope Process -Force
IEX (IWR 'https://raw.githubusercontent.com/redcanaryco/atomicredteam/master/
install-atomicredteam.ps1' -UseBasicParsing)
Install-AtomicRedTeam -getAtomics -Force
```

بدون اینترنت

اگر ماشین اینترنت ندارد: دو مخزن `redcanaryco/atomic-` و `redcanaryco/invoke-atomicredteam` را جای دیگری به صورت ZIP دانلود کنید، در `C:\AtomicRedTeam` باز کنید و مازول `powershell` را هم نصب کنید.

۷-۲. اجرای یک تست

در DetectKB، صفحه‌ی **Atomic Red Team** یا بخش **Atomic Red Team tests** صفحه‌ی قانون را باز کنید و خط `Invoke-AtomicTest` را کپی کنید. روی WIN-VICTIM:

```
Import-Module 'C:\AtomicRedTeam\invoke-atomicredteam\Invoke-AtomicRedTeam.ps1' -Force

# 1. Prerequisites (downloads the test's tools)
Invoke-AtomicTest T1003.001 -TestGuids 2536dee2-12fb-459a-8c37-971844fa73be -GetPrereqs

# 2. Run the attack
Invoke-AtomicTest T1003.001 -TestGuids 2536dee2-12fb-459a-8c37-971844fa73be

# 3. Clean up
Invoke-AtomicTest T1003.001 -TestGuids 2536dee2-12fb-459a-8c37-971844fa73be -Cleanup
```

۷-۳. دیدن نتیجه

۱. ۲ تا ۵ دقیقه صبر کنید تا لاگ‌ها به Splunk برسند.
۲. در Splunk، کوئری قانون (از صفحه‌ی قانون در DetectKB) را برای **۱۵ دقیقه‌ی اخیر** اجرا کنید.
۳. نتیجه داشت ← قانون کار می‌کند ✓ · نتیجه نداشت ← قانون یا لاگ مشکل دارد ✗
۴. بعد از چند تست، ماشین را به `Snapshot clean-baseline` برگردانید.

۸. بررسی سلامت لب

قبل از اولین تست، این جستجوها را در Splunk اجرا کنید. هر کدام باید نتیجه داشته باشد:

جستجو	چه چیزی
<code>index=sysmon stats count by EventCode</code>	رویداد Sysmon می‌رسد
<code>index=win EventCode=4688 table _time Process_Command_Line</code>	4688 همراه با خط فرمان
<code>index=win EventCode=4104 head 5</code>	اسکرپت (4104) PowerShell
<code> tstats count from datamodel=Endpoint.Processes by Processes.dest</code>	دیتامدل Endpoint پر است

و برای اینکه مطمئن شوید ماکروهای ESCU کار می‌کنند (نام ماکرو بین دو backtick است):

```
`sysmon` | head 5
```

عیب‌یابی رایج

اگر ماکروی `sysmon` نتیجه نمی‌دهد ولی `index=sysmon` نتیجه دارد، `index`ها در «Indexes searched by» `default` نقش شما نیستند (بخش ۴-۴).

۹. اتصال DetectKB به لب

اصل مهم: **DetectKB** هیچ وقت وارد ماشین های قربانی نمی شود و روی آن ها دستور اجرا نمی کند. اگر DetectKB رمز ادمین ماشین ها را داشت و خودش دستور اجرا می کرد، نفوذ به DetectKB یعنی نفوذ به لب. پس ارتباط ها این طور طراحی شده اند:

ارتباط	جهت	چطور	در کدام فاز
DetectKB → Splunk	DetectKB وصل می شود	REST API روی 8089 با توکن فقط خواندنی؛ کوئری قانون را در بازه ی زمانی تست اجرا می کند	فاز ۳
Runner → DetectKB	ماشین قربانی وصل می شود	یک اسکریپت کوچک PowerShell روی WIN-VICTIM که هر ۳۰ ثانیه از DetectKB می پرسد «تستی در صف هست؟»، اجرا می کند و زمان را گزارش می دهد	فاز ۳
→ DetectKB ماشین های قربانی	—	هیچ ارتباطی (نه RDP، نه WinRM، نه SSH)	هیچ وقت

در فاز ۲ (دستی)

هیچ اتصالی لازم نیست. تست را طبق فصل ۷ دستی اجرا می کنید، نتیجه را در Splunk می بینید و در DetectKB ثبت می کنید.

در فاز ۳ (خودکار)

- ۱ **کاربر در DetectKB:** روی قانون «این قانون را تست کن» را می‌زند؛ DetectKB تست Atomic مرتبط را در صف می‌گذارد.
- ۲ **Runner روی WIN-VICTIM:** هر ۳۰ ثانیه از DetectKB می‌پرسد «کاری هست؟» `HTTPS:443 → DetectKB` – DetectKB هیچ‌وقت به ماشین قربانی وصل نمی‌شود.
- ۳ **Runner:** تست را با `Invoke-AtomicTest` اجرا می‌کند و زمان شروع/پایان را به DetectKB گزارش می‌دهد؛ بعد Cleanup.
- ۴ **لاگ‌ها:** Sysmon و Event Log ها با Forwarder به SPLUNK-LAB می‌روند `9997`.
- ۵ **DetectKB:** چند دقیقه بعد، کوئری همان قانون را در همان بازه‌ی زمانی با REST API روی Splunk اجرا می‌کند
توکن فقط خواندنی `HTTPS:8089`
- ۶ **نتیجه:** نتیجه داشت ← **Detected** ✓ · نداشت ← **Not detected** ✗؛ در DetectKB ثبت می‌شود و قانون وضعیت **Validated** می‌گیرد.

شکل ۲ – مسیر یک تست خودکار: از دکمه در DetectKB تا ثبت نتیجه

حساب‌ها و دسترسی‌ها

حساب	کجا	دسترسی
detectkb_svc	Splunk لب	نقش جدید <code>detectkb_reader</code> : فقط <code>search</code> روی <code>indexهای win</code> ، <code>sysmon</code> ، <code>linux</code> ؛ بدون دسترسی ادمین. برایش یک Authentication Token بسازید.
توکن Runner	DetectKB	در DetectKB ساخته می‌شود و فقط اجازه‌ی «گرفتن تست از صف و گزارش نتیجه» دارد – نه خواندن یا تغییر قانون‌ها.
حساب اجرای Runner	WIN-VICTIM	کاربر محلی ادمین لب (بسیاری از تست‌ها دسترسی ادمین می‌خواهند). هیچ ربطی به حساب‌های سازمان ندارد.

۱۰. قواعد امنیتی لب

- لب در شبکه‌ی جدا؛ بدون مسیر به **production** و بدون Trust با Active Directory سازمان.
- هیچ رمز، کلید یا داده‌ی واقعی سازمان داخل لب نباشد.
- رمزهای لب (Splunk، ادمین ویندوز) با رمزهای سازمان فرق داشته باشد.
- استثنای آنتی‌ویروس فقط روی ماشین‌های لب.
- بعد از هر دوره‌ی تست، ماشین‌ها به Snapshot تمیز برگردند.
- دسترسی RDP و SSH فقط از جامپ‌سرور و برای افراد مشخص.
- بعد از نصب، دسترسی اینترنت ماشین‌های لب را ببندید یا محدود کنید.

۱۱. چک لیست تحویل

زیرساخت

- ☐ Port Group و Resource Pool LAB-ATTACK ساخته و از production جدا شده است.
- ☐ فایروال طبق جدول فصل ۲ تنظیم شده است.
- ☐ SPLUNK-LAB نصب، اپ‌ها نصب، indexها ساخته و دریافت روی 9997 فعال است.
- ☐ Snapshot clean- و WIN-VICTIM: Sysmon، Audit، Forwarder، Atomic Red Team نصب و baseline گرفته شده است.
- ☐ تمامی جستجوهای فصل ۸ نتیجه دارند.
- ☐ یک تست نمونه (T1003.001) اجرا و در Splunk دیده شده است.

اطلاعاتی که برای تنظیم DetectKB لازم است

مورد	مقدار
آدرس REST API اسپلنک	<code>https://splunk-lab.lab.local:8089</code>
توکن حساب <code>detectkb_svc</code>	(به صورت امن تحویل داده شود – نه در ایمیل یا چت)
نام indexها	<code>win, sysmon, linux</code>
نام ماشین‌های قربانی	<code>WIN-VICTIM, ...</code>
آیا Defender در حالت استثنا است؟	بله / خیر
باز بودن مسیر <code>8089 → DetectKB</code> و <code>Runner → DetectKB:443</code>	بله / خیر